

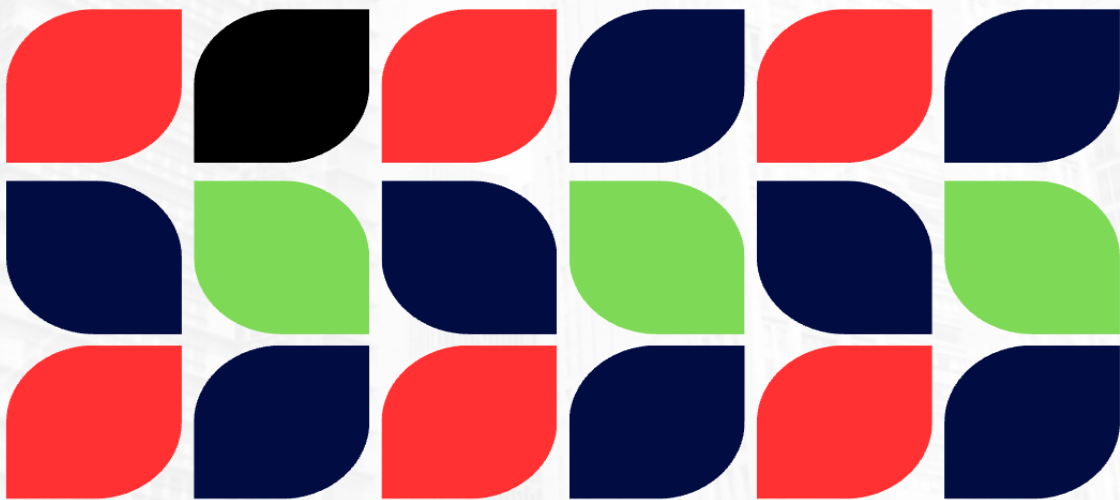
2025

GRC104 GlobalSync Inc. Compliance Crisis Assessment

GRC104: Compliance Frameworks and Legal
Requirements

Prepared By : Shirizane Magadla

Date: 11 November 2025



GlobalSync Inc. Compliance Crisis Assessment

Prepared by: Shirizane Magadla

Student No: 2025/GRC/10280

Educator: Miss Sharon

Date: 10 November 2025

Part 1: The Initial Discovery & Risk Triage

Introduction:

As the new Chief Compliance Officer, my priority was to understand the scope and seriousness of the whistleblower allegations. This section identifies the regulations at risk, the potential legal consequences, and the nature of each compliance failure. This triage is essential for prioritizing our response and protecting the company's reputation and merger prospects.

Task 1.1: The Whistleblower Email

Allegation	Main Regulation at Risk	Potential Legal Impact	Key Dimension
A: EU customer data sent to US without proper legal basis	GDPR (EU data privacy law)	Large fines, possible halt on EU data transfers, regulatory investigation	Unintentional, Systemic
B: Brazilian sales team offering "incentives" for contracts	FCPA (US anti-bribery law), Brazil Clean Company Act	Criminal/civil penalties, reputational damage, debarment from contracts	Intentional, Systemic
C: No central process for customer data deletion requests	GDPR, CCPA/CPRA (California), LGPD (Brazil)	Fines, lawsuits, loss of customer trust, regulatory scrutiny	Unintentional, Systemic
D: Can't prove financial controls work	SOX (Sarbanes-Oxley Act)	Regulatory action, investor distrust, merger complications	Unintentional, Systemic
Note: Each issue exposes GlobalSync to significant legal, financial, and reputational risk. Allegations A and C are likely due to process gaps from rapid growth, while B suggests a deeper cultural or ethical problem.			

Task 1.2: Risk Assessment Matrix

To prioritize our response, I used a 5x5 risk matrix to assess the likelihood and impact of each allegation. This helps us focus on the most urgent threats to the company.

	Insignificant	Minor	Moderate	Major	Catastrophic
Almost Certain					
Likely				B	
Possible			D		
Unlikely					
Rare					A
			C		
Placement Justification:	• A (EU Data Transfer): Catastrophic if regulators act, but rare if controls exist. <i>Note: Losing EU data transfers could cripple our EU business and halt the merger.</i> • B (Bribery): Major and likely, as sales pressure can make this systemic. <i>Note: Bribery can result in criminal charges and loss of government contracts.</i> • C (Data Deletion): Moderate and possible. Not as severe as A or B yet, but could escalate if publicized. <i>Note: This is a common gap in fast-growing tech companies and can quickly become a major issue.</i> • D (Financial Controls): Minor to moderate and possible. Serious for investor confidence, especially during a merger. <i>Note: This could delay or derail the merger if not addressed.</i>				

Part 2: The Compliance Audit Deep Dive

With the main risks identified, I initiated a targeted compliance audit. This section outlines the audit's scope, evidence-gathering plan, and a sample audit finding. The goal is to confirm the facts, understand root causes, and provide a solid foundation for remediation.

Task 2.1: Scoping the Audit

Area	Business Units Involved	Data/Process Examined	Key Audit Questions
EU Data Transfers	IT, Legal, Data Operations	EU customer data exports	Are legal protections in place and working?
Bribery in Brazil	Sales, Compliance, Legal	Sales contracts and incentives	Are anti-bribery controls effective?
Data Deletion Requests	Customer Support, IT, Privacy	Processing and tracking of DSRs	Are deletion requests logged and completed?
Financial Controls	Finance, Internal Audit	SOX-related controls and documentation	Are controls documented and tested regularly?
Note: The audit focuses on the business units and processes directly linked to the allegations, ensuring we address both technical and human factors.			

Task 2.2: Evidence Gathering Plan (Allegation A)

For the most urgent risk, improper EU-US data transfers, I developed a mini-plan to gather evidence through documents, interviews, and testing.

Step	Details
Document Review	1. Data Processing Agreements (DPAs) with EU clients 2. Standard Contractual Clauses (SCCs) or Binding Corporate Rules (BCRs) 3. Data flow diagrams showing actual transfers
Interviews	• Data Protection Officer (DPO): 1. What legal basis do we use for EU-US transfers? 2. How do we check ongoing compliance? • IT Infrastructure Lead: 1. How does data move from the EU to the US? 2. How is it protected during transfer? • Legal Counsel (Privacy):

	1. Are contracts up to date with GDPR and Scherms II? 2. How do we handle regulatory requests?
Testing	Select a sample of EU client data and trace its journey. Check if every transfer to the US is covered by a legal agreement and if encryption or other protections are in place.
Note: This approach ensures we check both documentation and real-world practices, not just what's on paper.	

Task 2.3: Drafting the Audit Finding (Allegation C)

After confirming the failure to process data deletion requests, I drafted a formal audit finding using the required structure.

Element	Content
Condition	No formal, centralized process for handling customer data deletion requests; 40% of sampled requests were never completed.
Criteria	GDPR Article 17: Companies must honor "right to erasure" requests and respond within one month.
Cause	Lack of a tracking system and clear ownership; requests are handled informally by different teams.
Effect	Risk of major fines, lawsuits, loss of customer trust, and negative impact on the merger.
Risk Rating	High. This is a widespread, ongoing failure to meet a core legal requirement, likely to be noticed by regulators or customers.
Note: This is a classic process breakdown that often happens when rapid growth outpaces compliance infrastructure.	

Part 3: Navigating the Legal & Regulatory Maze

With the facts established, we must now respond to regulators and legal threats. This section covers how we answer regulatory inquiries, handle lawsuits, and manage government investigations, all of which are critical to protecting the company's future.

Task 3.1: The Regulator Knocks

Question	Answer
What are the possible mechanisms for legal data transfer under the GDPR post-Scherms II?	• Standard Contractual Clauses (SCCs) • Binding Corporate Rules (BCRs) • Specific consent from data subjects (rare cases)
Which is the most robust, and what must GlobalSync do to implement it?	BCRs are the most robust. To implement, GlobalSync must document internal rules, train staff, and pass regulatory checks with EU authorities.
If found in violation, what is the maximum potential fine under GDPR?	€20 million or 4% of global revenue, whichever is greater.
Note: Regulators are strict on these rules. Not having a solid mechanism could shut down our EU business and derail the merger.	

Task 3.2: The Lawsuit

Question	Answer
Under which California law does this lawsuit fall?	CCPA/CPRA (California Consumer Privacy Act/Privacy Rights Act)
What specific "consumer right" has been violated?	The right for consumers to request deletion of their personal data.
What is a key difference between the private right of action in the CCPA/CPRA vs. the GDPR?	Under CCPA/CPRA, consumers can sometimes sue companies directly (private right of action), while under GDPR, complaints mostly go through regulators.
Note: In California, ignoring deletion requests can lead to lawsuits as well as regulator action, increasing both legal and reputational risk.	

Task 3.3: The Settlement Dilemma

Question	Answer
What is a DPA, and what are two key benefits for GlobalSync in accepting it?	A Deferred Prosecution Agreement (DPA) is a deal where prosecution is paused if the company meets certain conditions. Benefits: 1) Avoids a public criminal conviction (protects reputation and ability to do business); 2) Allows us to keep operating (including government contracts) while we fix the problems.
What is one major obligation the company will likely have to fulfill under this DPA?	Launch a strong anti-bribery program, possibly with an outside monitor checking our progress.
Note: A DPA is a second chance, but comes with strict oversight and reporting requirements.	

Part 4: Strategic Roadmap & Board Presentation

The final part of my assessment is about solutions and leadership. Here, I lay out a clear plan to fix our biggest compliance gap and set the right tone for the Board. This is where we move from identifying problems to building a stronger, safer company.

Task 4.1: Corrective Action Plan: Allegation C

Action Item	Owner (Department)	Target Date	Success Metric
Build a central system to track all deletion requests	IT & Privacy	90 days	100% of requests tracked and closed within 30 days
Train all customer-facing staff on deletion request procedures	HR & Privacy	60 days	95% staff trained, post-training quiz scores
Assign a Data Deletion Lead for each major region	Privacy Office	30 days	Each region has a named owner, with monthly reporting
Note: The plan focuses on clear responsibilities, deadlines, and measurable outcomes so we know when the problem is fixed.			

Task 4.2: The "Tone at the Top"

Board Opening Statement:

Directors, compliance is not just about avoiding penalties; it's about protecting our growth, reputation, and the trust that makes us a partner of choice. With the upcoming merger, our ability to prove strong compliance will decide GlobalSync's future. I am committed to building a culture where compliance is a strategic asset and a shared responsibility.

NB: This message reassures the Board that compliance is central to our business success, not just a legal chore.

Bonus Challenge: The Future-Proofing Question

To prevent future crises, we must look ahead and invest in trends that will keep us safe and competitive. Here's my recommendation:

Trend	Why Invest?
Privacy-Enhancing Technologies (PETs)	PETs which is strong data encryption, anonymization, and secure data sharing tools reduce privacy risks by design. This future-proofs us as privacy laws tighten worldwide and shows customers, we take their data seriously.
Note: This is a proactive investment that will save headaches, costs, and reputational damage in the long run.	